

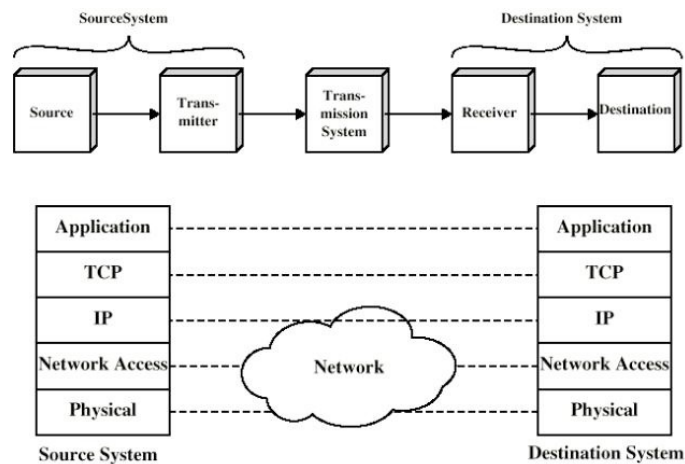
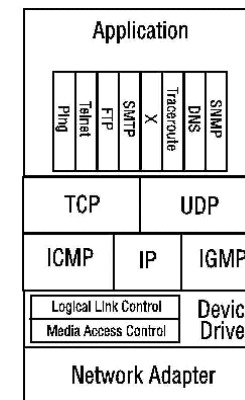
REDES Y SEGURIDAD II



Seguridad en (servidores de) Internet

Capa de aplicación

- Nivel más alto
 - Aplicaciones visibles para el usuario
 - Ofrece acceso al resto
- Más propensa a ataques
 - Variedad de aplicaciones
 - Dependencia del resto de niveles





Seguridad Servidores Web

- Primer concepto por Vannebar Bush (1940)
 - Nombre original: MEMEX
 - Información distribuida e interrelacionada
 - Acceso a artículos relevantes identificados por claves
- Creado en el CERN (1989)
 - Tim Berners-Lee
 - Nombre original: ENQUIRE
 - Publicado en 1992 (ayuda de Robert Cailliau)
 - Licencia abierta en 1993



Seguridad Servidores Web

- Una de las muchas caras públicas de la institución
- Debido a su exposición son potencialmente un blanco fácil

¿Cómo compartir la información institucional sin abrir una puerta a intrusiones?

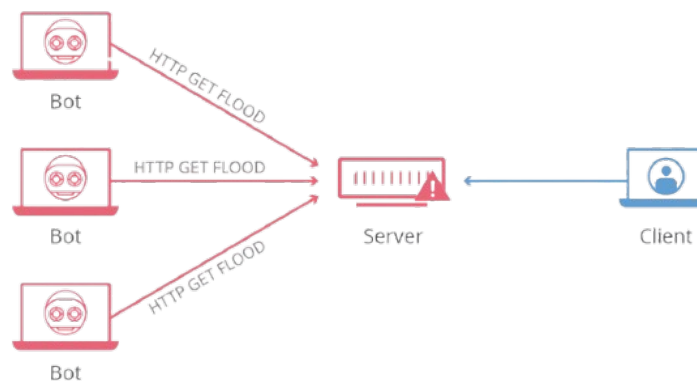


Seguridad Servidores Web

- **Denegación de Servicio (DoS)**

- Diferentes niveles
 - Peticiones masivas al servicio para consumir recursos del sistema
 - Ancho de banda, procesador, memoria, ...
 - Ataque a protocolos inferiores (TCP SYN Flood, Smurf, ...)
- No dejan espacio a peticiones legítimas
- El consumo se suele traducir en un coste económico adicional

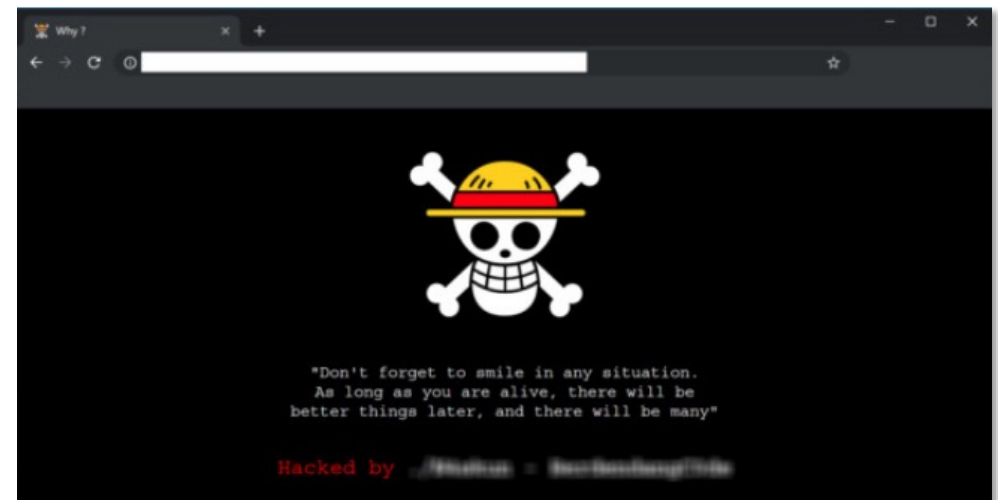
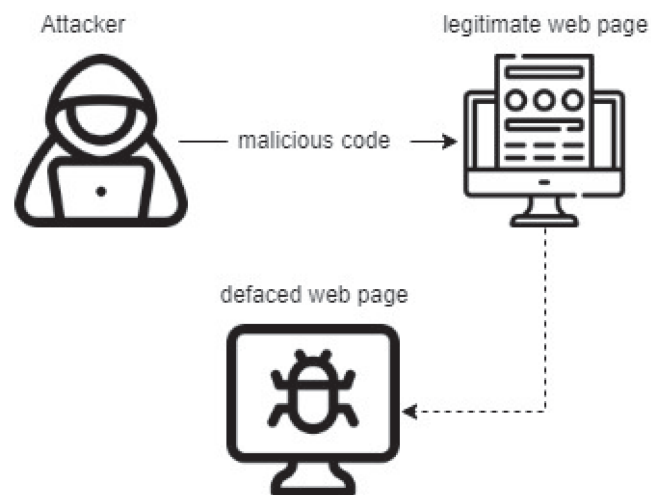
¿Qué contramedidas se pueden utilizar?



Seguridad Servidores Web

- **Desfiguración de la página web**

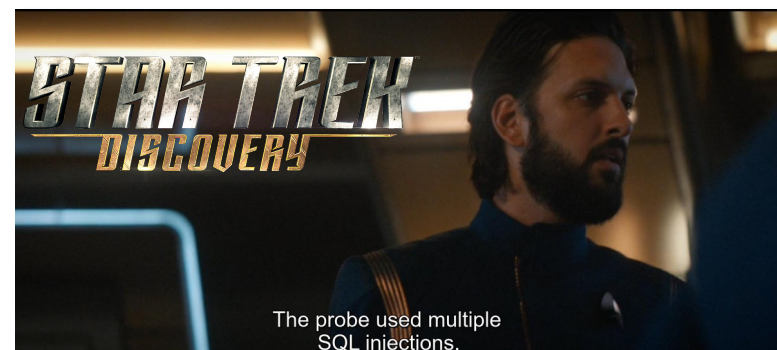
- Modificación ilícita del contenido
- Aprovecha fallo de la configuración
 - Herramientas del proveedor de hosting
 - Configuración por defecto
- Daño a la reputación de la institución que luego puede repercutir económicamente



Seguridad Servidores Web

- **Inyección código**

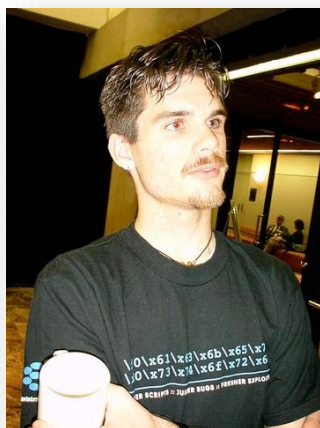
- Infiltración de código intruso
- Aprovechando vulnerabilidad existente en aplicaciones a nivel de validación de las entradas
 - Chequeo/filtrado incorrecto de las variables del programa
- Aplicación genera sentencia SQL en tiempo de ejecución
- Realización a través de lenguaje intermedio (PHP, Ruby on Rails, Perl, Java, ...)
- Código objetivo: SQL (el más común) y HTML



Seguridad Servidores Web

• Inyección código SQL

- Primera descripción en Phrack #54 por Rainforestpuppy (1998)
 - Discusión sobre exploits basados en Microsoft SQL y ASP
- Prácticamente todos los gestores de contenido actuales (Wordpress, Joomla!, ...) requieren una base de datos
- Ejemplo PHP + SQL



```
$usuario=$_POST['usuario'];  
$password=$_POST['password'];  
$sql="SELECT * FROM usuarios WHERE  
usuario='$usuario' AND  
password='$password';  
$result=mysql_query($sql);
```

SELECT * FROM usuarios WHERE usuario='a' AND password='a' OR '1=1'



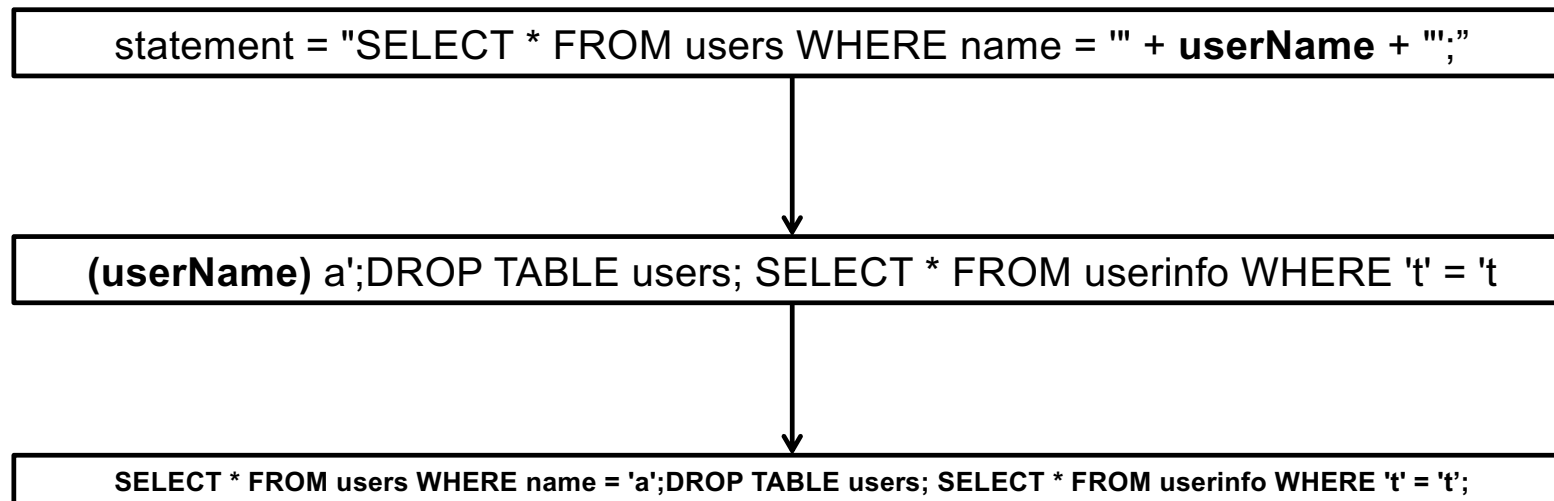


Seguridad Servidores Web

- **Inyección código SQL**

- **Caracteres incorrectamente delimitados (“escapados”)**

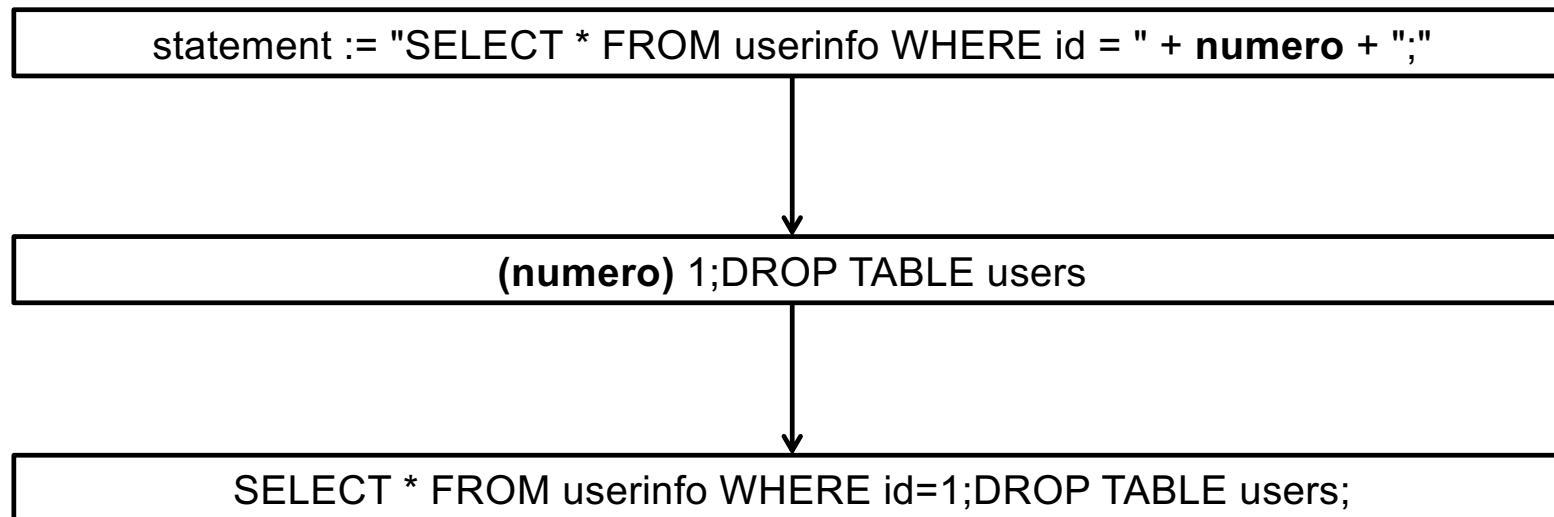
- Se pueden añadir comentarios para bloquear el resto de sentencias SQL (--,{,/*)





Seguridad Servidores Web

- **Inyección código SQL**
 - **Tipo de variable manejado incorrectamente**
 - Carece de tipo o no se valida





Seguridad Servidores Web

- **Inyección código SQL**

- **Inyección ciega**

- Resultados no visibles al atacante aunque sí un cambio de comportamiento de la página

(Normal) SELECT booktitle FROM booklist WHERE bookId = 'OOK14cd' **AND '1'='1';**

(Diferente) SELECT booktitle FROM booklist WHERE bookId = 'OOK14cd' **AND '1'='2';**



SELECT 1/0 FROM users WHERE username='ooo';

Seguridad Servidores Web

- **Inyección código SQL**
 - Clasificación de vectores de ataque para la inyección de código SQL (SQLIA) 2010



Classification parameters	Methods	Techniques/ Implementation	
Intent	Identifying injectable parameters	see 'Input type of attacks'	
	Extracting Data		
	Adding or Modifying Data		
	Performing Denial of Service		
	Evading detection		
	Bypassing Authentication		
	Executing remote commands		
	Performing privilege escalation		
Input Source	Injection through user input	Malicious strings in Web forms	URL: GET- Method Input filed(s): POST- Method
	Injection through cookies	Modified cookie fields containing SQLIA	
	Injection through server variables	Headers are manipulated to contain SQLIA	
	Second-order injection	Frequency-based Primary Application	
		Frequency-based Secondary Application	
		Secondary Support Application	
		Cascaded Submission Application	
Input type of attacks, technical aspect	Classic SQLIA	Piggy-Backed Queries	
		Tautologies	
		Alternate Encodings	
		Illegal/ Logically Incorrect Queries	
		UNION SQLIA	
		Stored Procedures SQLIA	
	Inference	Classic Blind SQLIA	Conditional Responses
			Conditional Errors
			Out-Of-Band Channeling
		Timing SQLIA	Double Blind SQLIA (Time-delays/ Benchmark attacks)
			Deep Blind SQLIA (Multiple statements SQLIA)
	DBMS specific SQLIA	DB Fingerprinting	
		DB Mapping	
	Compounded SQLIA	Fast-Fluxing SQLIA	

Seguridad Servidores Web

- Inyección código SQL



 **Ian Coldwater** 
@IanColdwater

Probably should have anticipated that making my Animal Crossing character name a SQL injection string would cause all kinds of problems with associated apps/sites 🤖

[Traducir Tweet](#)

11:23 p. m. · 27 abr. 2020 · [Twitter for iPhone](#)

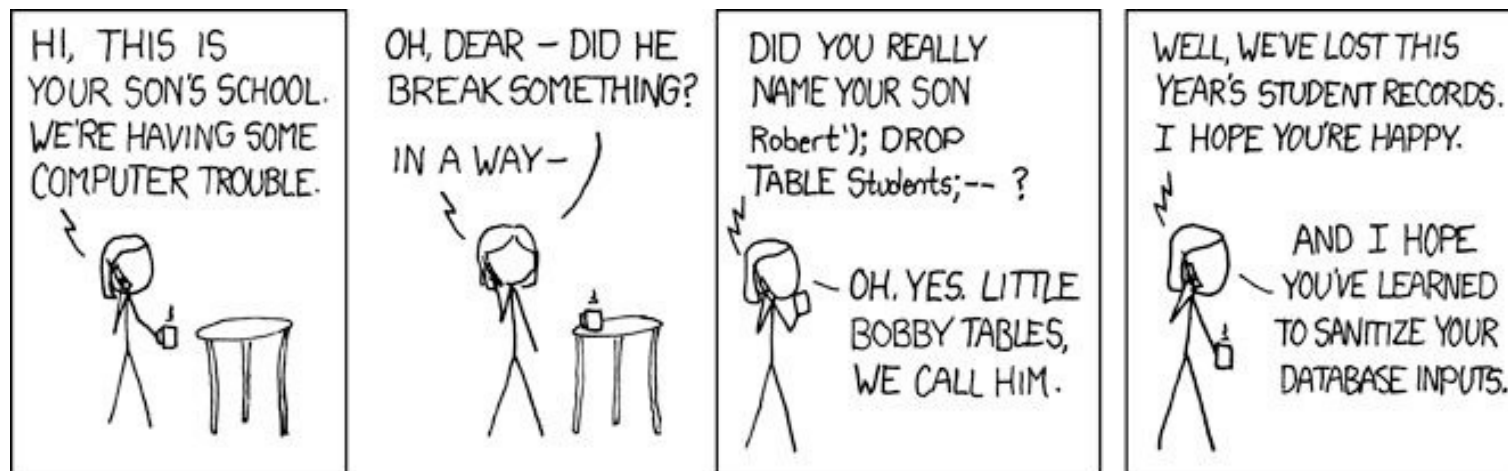


Seguridad Servidores Web

- **Inyección código SQL**

- **Contramedidas**

- Parametrización de sentencias SQL a través de funciones intermedias
 - Delimitación usando una lista negra de caracteres reservados
 - Verificación de patrones para los tipos de datos
 - Gestión de permisos en las bases de datos





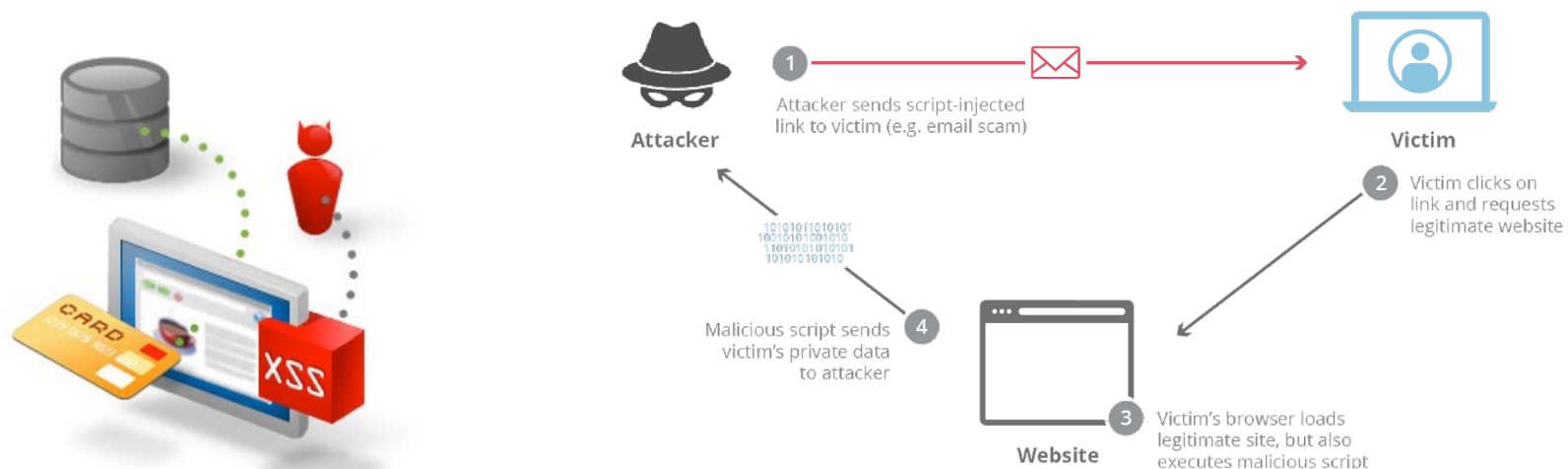
Seguridad Servidores Web

- **Protección frente a inyección SQL**
 - Separación entre servidores web de uso interno y uso externo
 - Contenidos diferenciados entre intranet e internet
 - Servidores web separados del segmento de desarrollo y producción
 - Disminuye el botín en caso de ataque exitoso
 - Monitorización constante
 - Archivos de eventos y escaneo de vulnerabilidades
 - Actualización regular del sistema
 - Tanto del servidor web como de los componentes instalados (CMS, bases de datos, ...)
 - Adopción de prácticas de programación seguras
 - Formación de los desarrolladores

Seguridad Usuarios Web

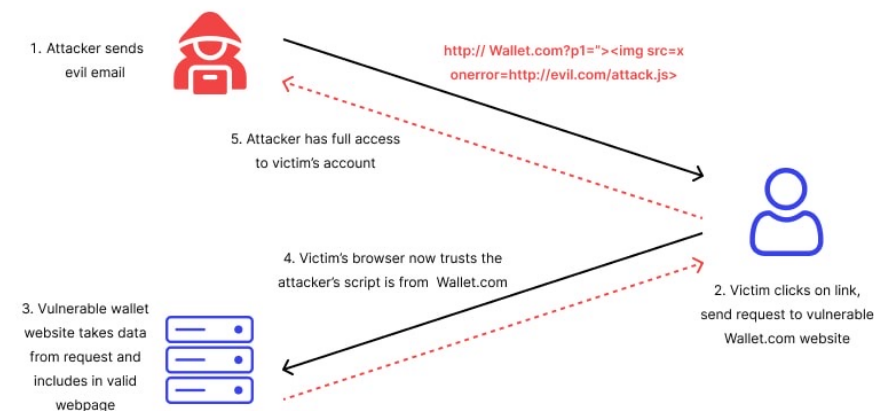
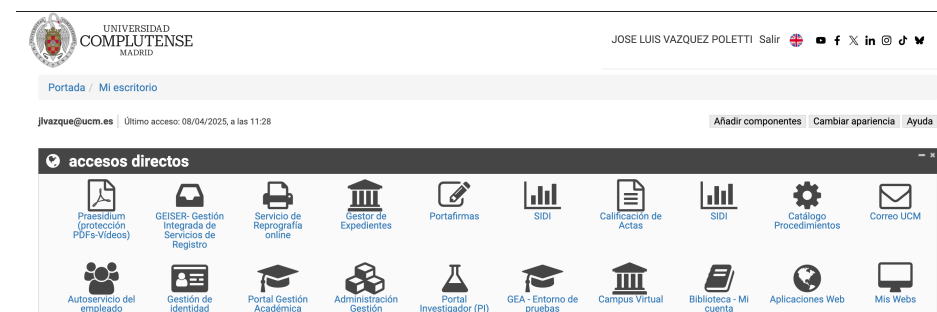
- **Cross-site scripting (XSS)**

- Tipo particular de inyección de código debido a:
 - No validación de los datos de entrada
 - No saneamiento de la salida para presentación en página web
- Atacante inyecta HTML o JavaScript en páginas web vistas por la víctima
 - El ataque se refleja en el navegador web de la víctima



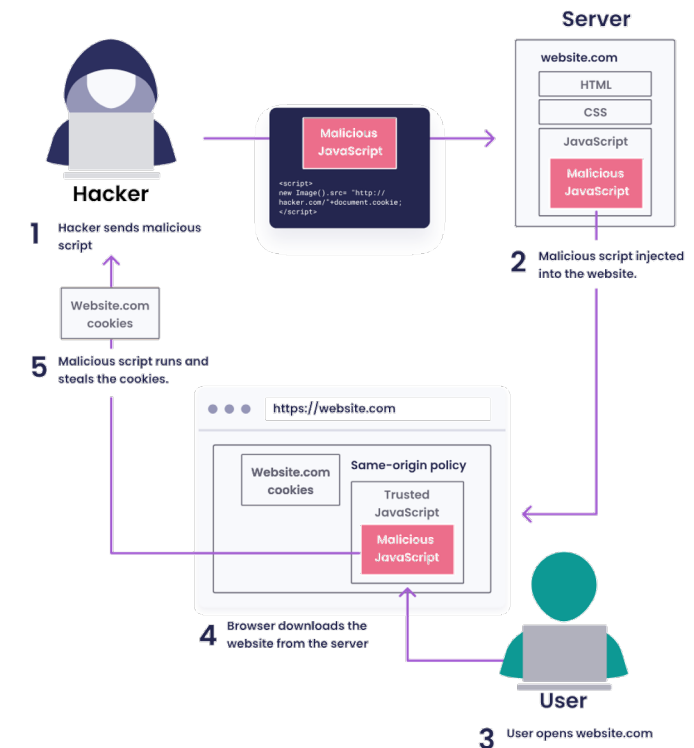
Seguridad Usuarios Web

- **XSS Indirecto (reflejado o no persistente)**
 - El tipo más común
 - Basado en que los documentos HTML tienen una estructura plana que mezcla las secuencias de control, formato y el contenido
 - Modifica valores que la aplicación web utiliza para pasar variables entre dos páginas
 - El vector de ataque más habitual suele ser un motor de búsqueda
 - La cadena de búsqueda se incluye en la petición y a continuación aparece en el contenido de la página de resultados
- Ejemplos:
 - E-mail con un enlace hacia un sitio legítimo (pero vulnerable) pero conteniendo el vector XSS
 - Vulnerabilidad XSS en Google explotada por sitios atacantes expone a todos los usuarios que los visitan desde el buscador



Seguridad Usuarios Web

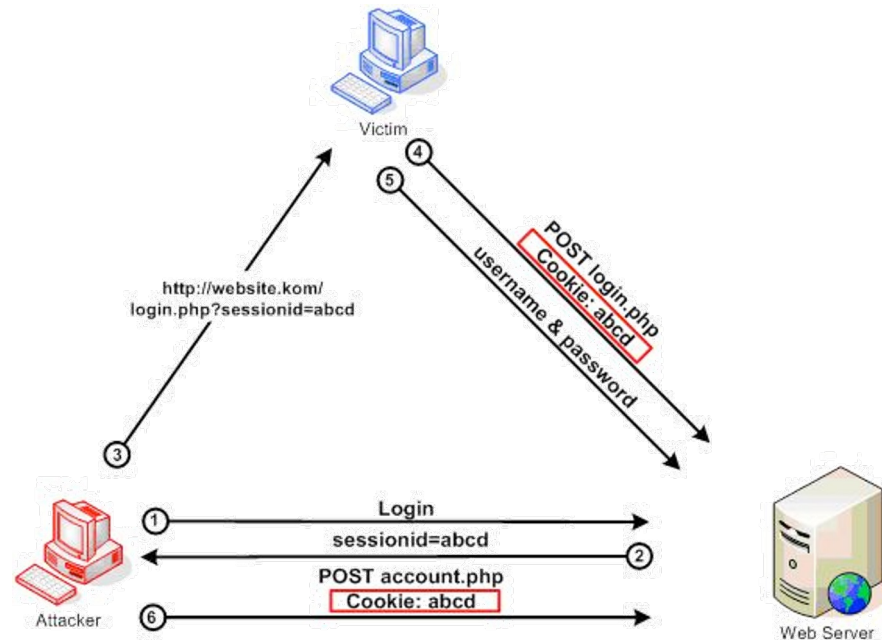
- **XSS Directo (almacenado o persistente)**
 - Variante más devastadora
 - No está dirigido a una víctima individual
 - Los datos proporcionados por el atacante son almacenados en el servidor
 - Mostrados de forma permanente en las siguientes páginas mostradas a otros usuarios
 - Ejemplo:
 - Foros en los que se permite introducir HTML a sus usuarios
 - En redes sociales llega a convertirse en un gusano que se propaga entre perfiles



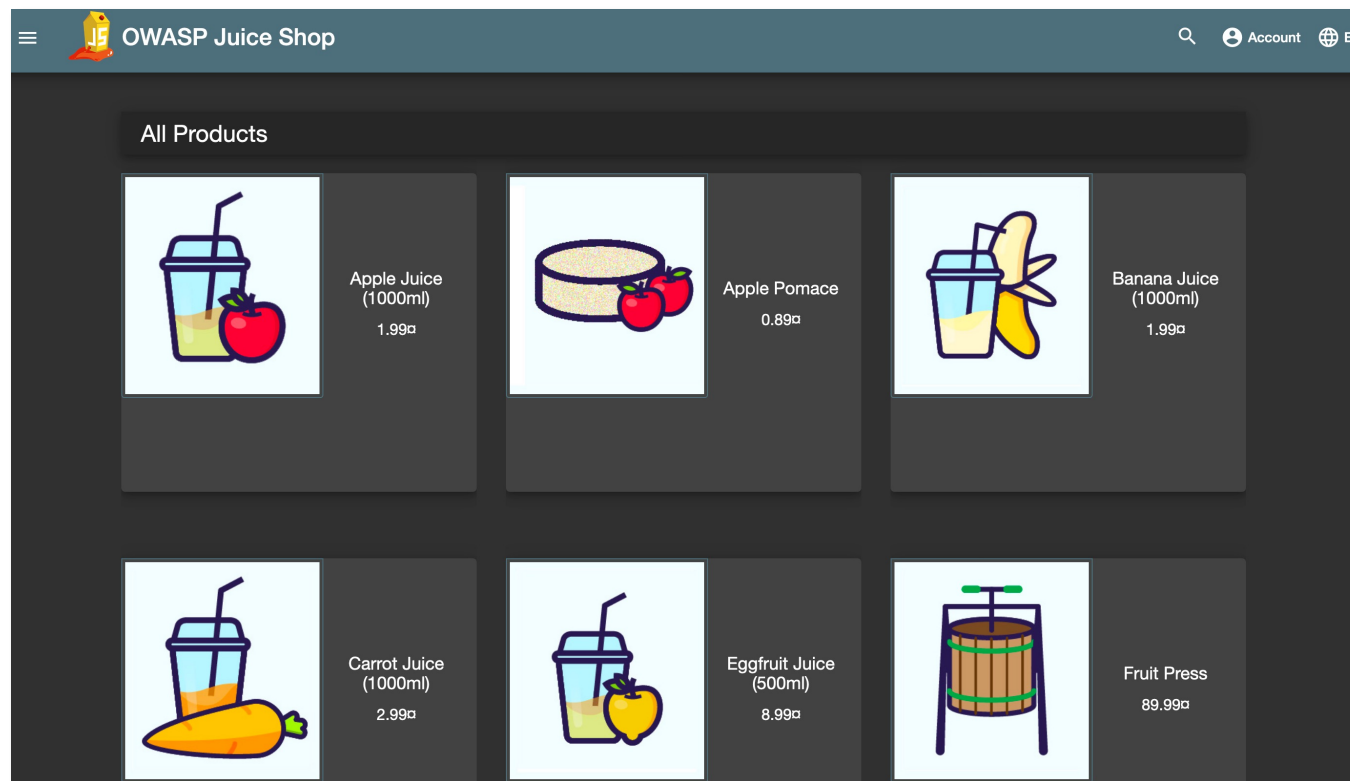
Seguridad Usuarios Web

• Contramedidas para Vulnerabilidades XSS

- Control de los datos de entrada y salida
 - Delimitación y codificación
- Validación del HTML introducido
- Seguridad en las cookies
 - Mitigar el robo de su usuario legítimo
- Limitar el uso de lenguajes de scripting
 - Módulos adicionales del navegador



Seguridad Web



<https://juice-shop.herokuapp.com/>

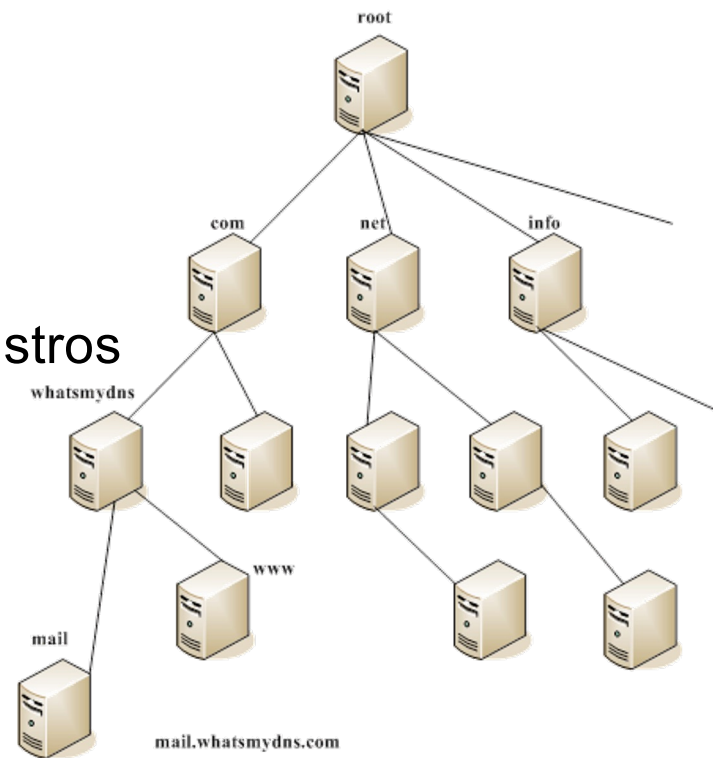
Seguridad DNS

- Domain Name System
- Creado por Paul Mockapetris (IBM, 1970)
 - Por ahora no hay tecnología que lo reemplace
- Objetivos:
 - Traducir números IP a nombres textuales más fácil de tratar por seres humanos
 - Compartimentalizar el soporte a diferentes servicios de red
 - Subdominios (correo.ejemplo.com, ftp.ejemplo.com)



Seguridad DNS

- Resto de servicios dependen de DNS
- Propiedades:
 - Diferentes tipos de consultas
 - Directos, inversos, alias
 - Administración distribuida
 - Estructura jerárquica
 - Rendimiento y fiabilidad
- Información estructurada en registros
 - SOA, A, CNAME, NS, MX, TXT, ...



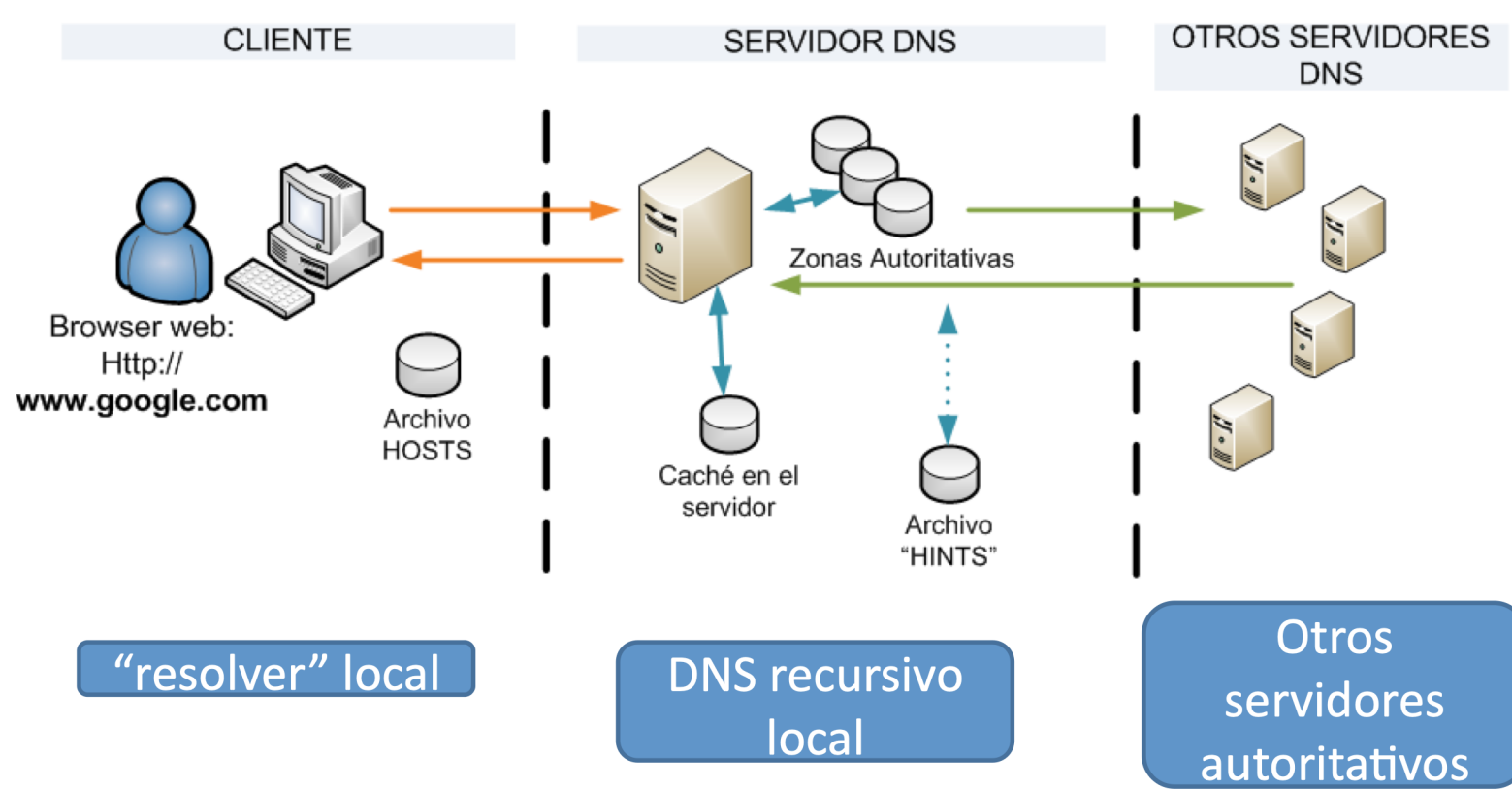


Seguridad DNS

- Información estructurada en registros
 - **A:** dirección IP de nombre de dominio (ejemplo: servidores de alojamiento)
 - **AAAA:** lo mismo pero para IPv6
 - **CNAME:** alias para nombre de dominio
 - **NS:** relación entre nombre de dominio y servidores DNS que almacenan su información
 - **MX:** asocia nombre de dominio a sus servidores de intercambio de correo
 - **PTR:** inverso de registro A (o de AAAA)
 - **SOA:** información del servidor DNS primario de zona
 - **HINFO:** descripción del host
 - **TXT:** permite a dominios identificarse de modo arbitrario
 - **SPF (campo dentro de TXT):** ayuda a combatir spam (indica los hosts autorizados a enviar correo)
 - **LOC:** coordenadas del dominio
 - **SRV:** servicios ofrecidos por dominio (reemplaza a WKS)

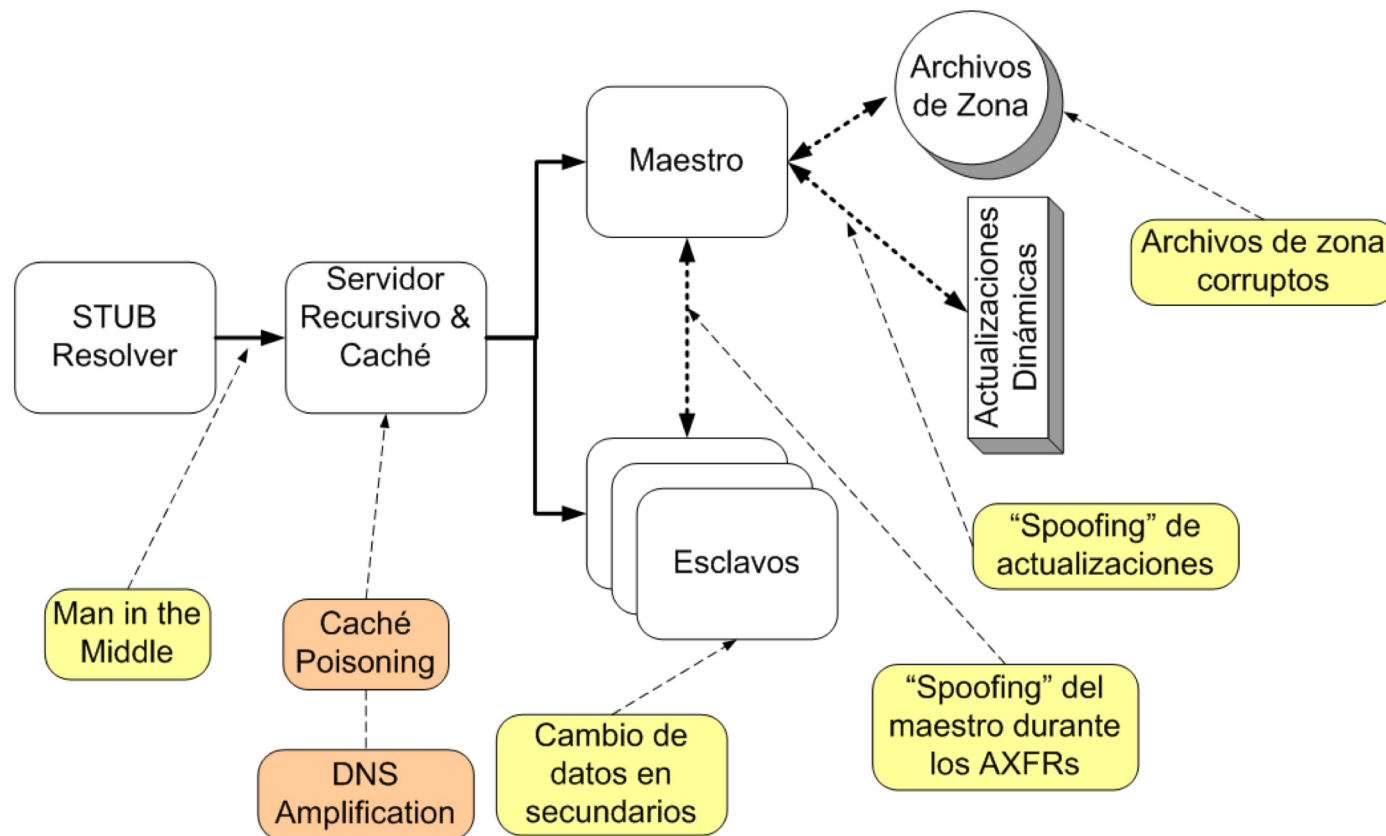
Seguridad DNS

- Esquema de consulta DNS



Seguridad DNS

- Múltiples vectores de ataque posibles



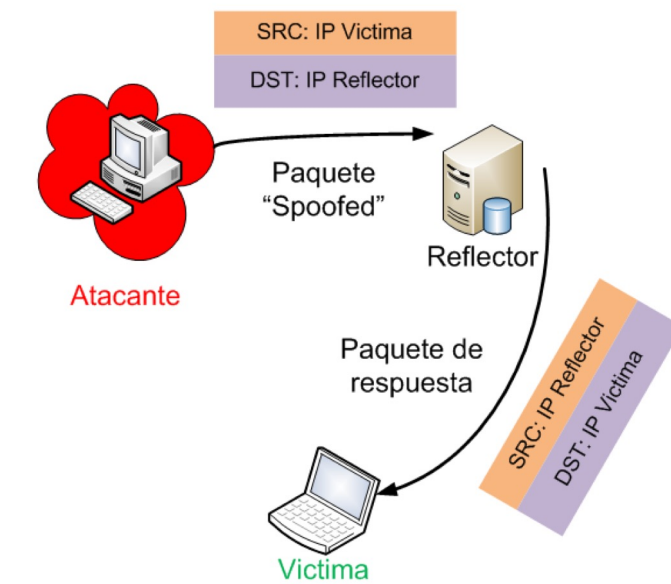
Seguridad DNS

• Ataque local



Seguridad DNS

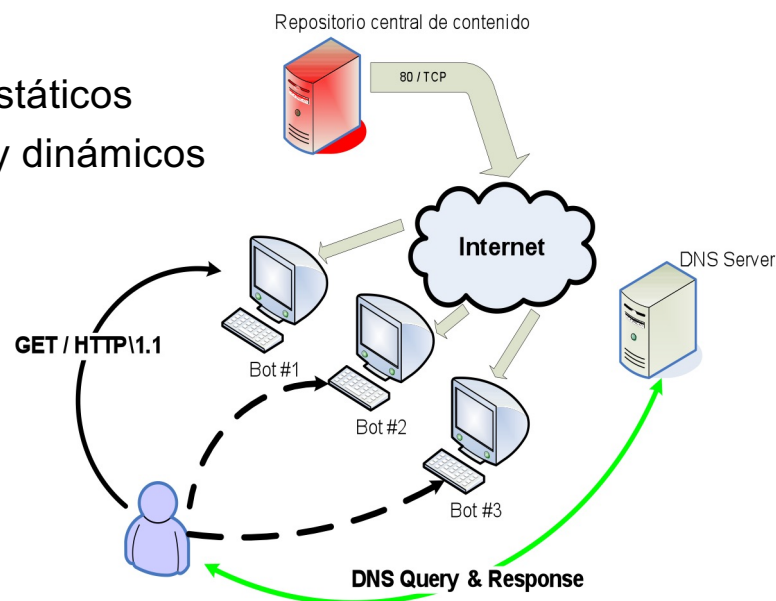
- **Ataques de amplificación**
 - Uso de servidores recursivos abiertos
 - Servidor reflector almacena registros grandes en caché
 - Típicamente registros TXT
 - Consultas falsificando IP de origen



Seguridad DNS

- **Fast Flux Service Networks**

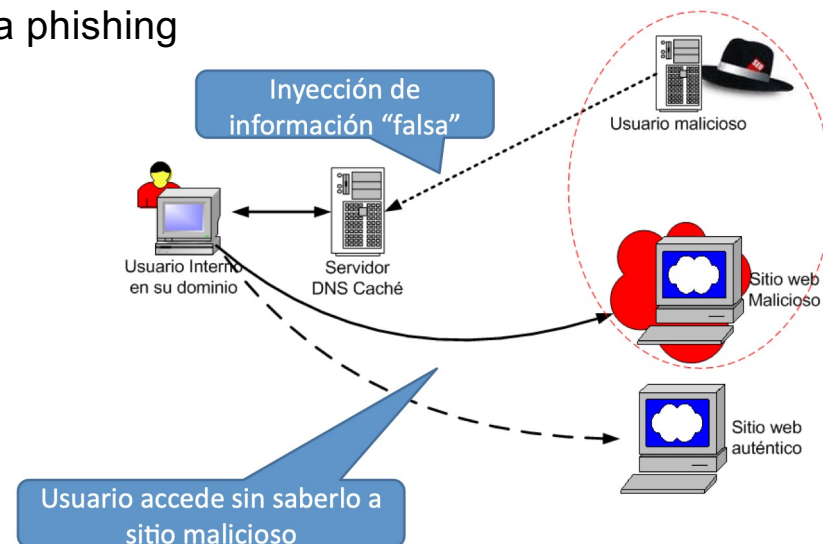
- Uso de botnet
 - Máquinas actúan como servidores DNS
- TTLs muy pequeños
- Múltiples registros A devueltos por DNS y cambiantes en el tiempo
- Uso de registros NS
 - Single flux: pocos y estáticos
 - Double flux: muchos y dinámicos



Seguridad DNS

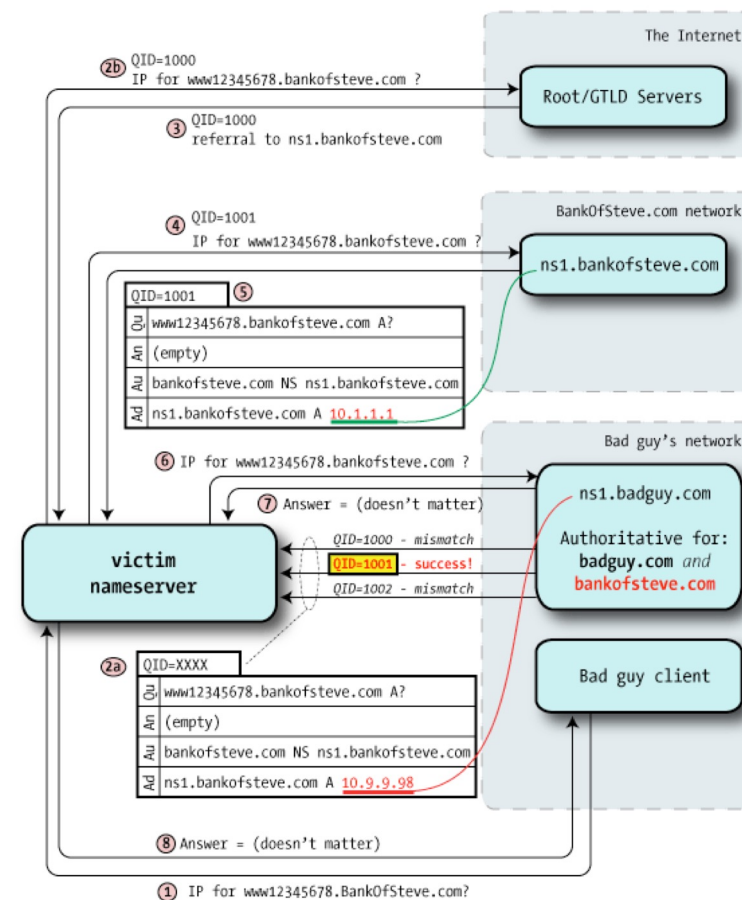
• Envenenamiento de Caché

- Hacer creer a servidor DNS que ha recibido información auténtica y válida
- Servidor DNS usa esta información para responder a otras consultas
- Objetivos:
 - Redirección a sitios dedicados a phishing
 - Robo de información
 - Restricciones gubernamentales



Seguridad DNS

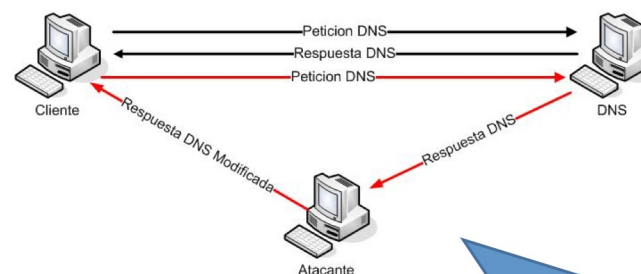
- **Bug Kaminsky (2008)**
 - Dan Kaminsky (CISCO)
 - Tipo de envenenamiento
 - Afecta a registros NS y no A
 - Redirección de consultas a DNS controlado por atacante



Seguridad DNS

• DNSSEC

- Extensiones de seguridad para DNS
 - Desarrollados por IETF
- Protección frente a inyección de datos falsificados
- Firmas digitales para respuestas
 - Autenticidad de originador
 - Autenticidad de la no existencia de información
 - Integridad de datos transferidos

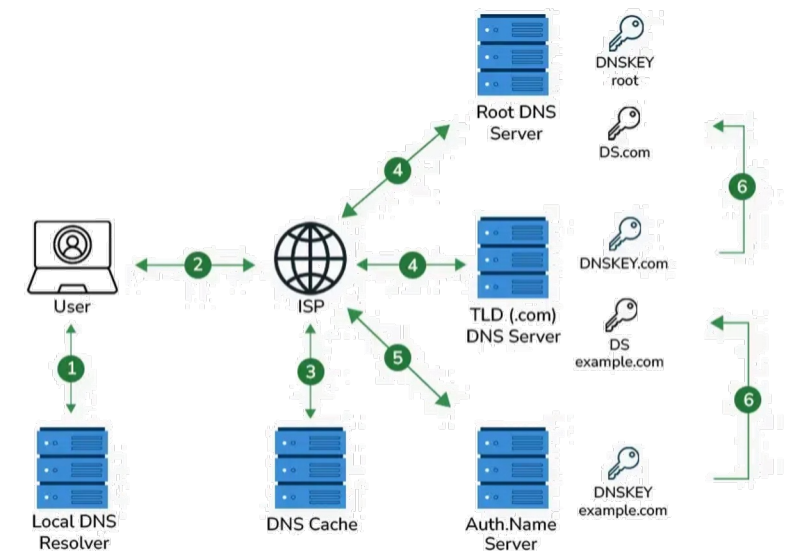
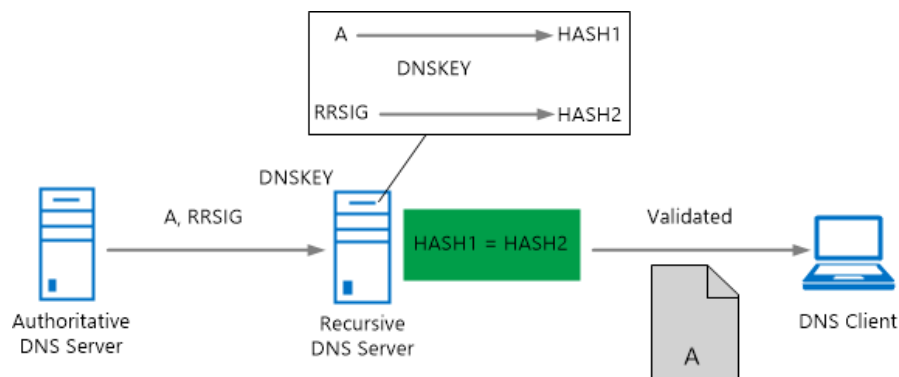


Notar que DNSSEC no elimina la posibilidad de inyectar información falsa en una transacción de DNS, sino que proporciona un mecanismo para autenticar el mensaje de respuesta transferido

Seguridad DNS

• DNSSEC

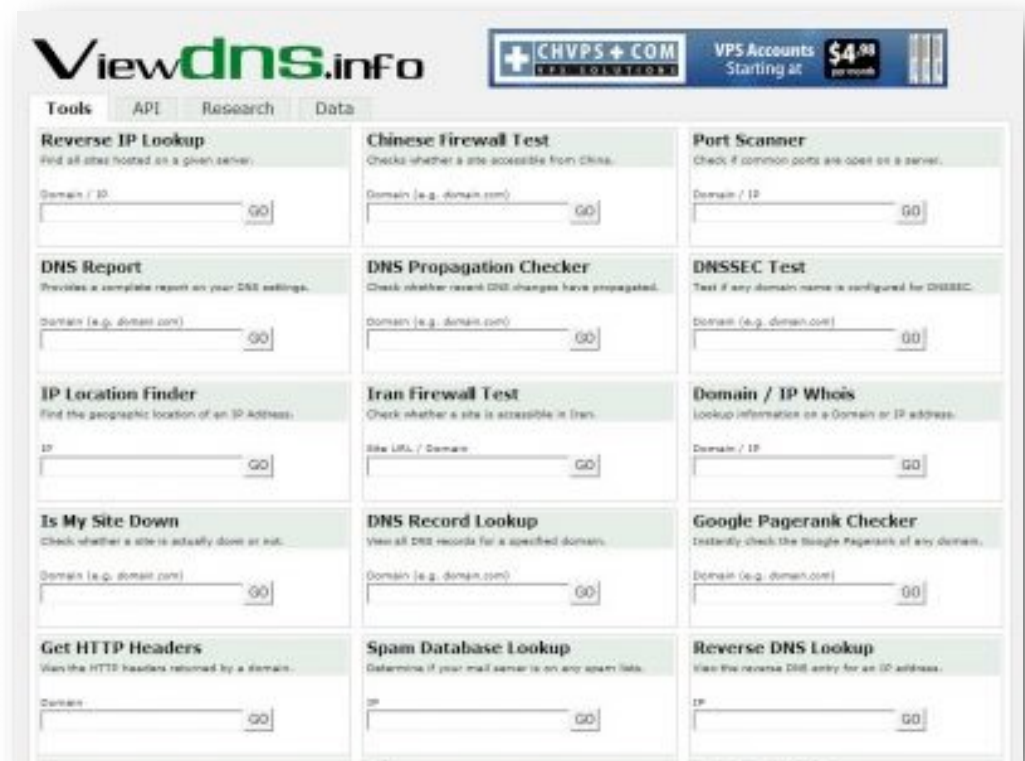
- Nuevos registros
 - **DNSKEY**: clave pública con la que se firman zonas
 - **RRSIG**: hash encriptado
 - **NSEC**: respuesta específica para los casos de búsqueda fallida
 - **DS**: hash de clave pública de zona hija
- Grado de despliegue: <https://stats.labs.apnic.net/dnssec>





Seguridad DNS

- **ViewDNS.info**
 - Diferentes herramientas DNS
 - Obtención de registros
 - Reverse IP
 - Comprobación de firewalls gubernamentales
 - Comprobación de DNSSEC
 - Otras herramientas

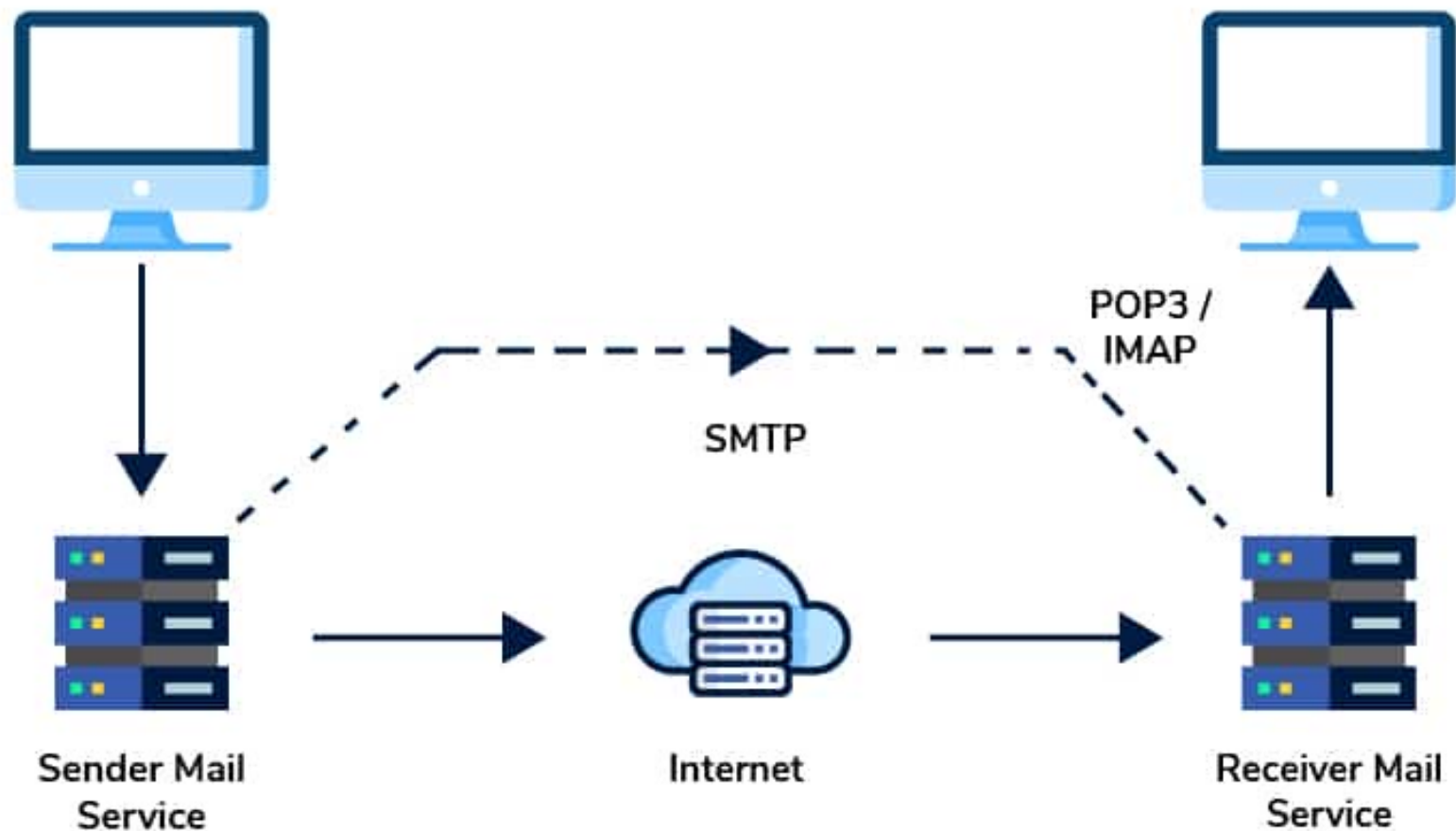


Seguridad de Servidores de E-mail

- Primer concepto por Ray Tomlinson (BBN, 1971)
 - Programa SNDMSG (enviar correo)
 - Programa READMAIL (leer correo)
 - Uso de “@” para separar nombres de usuario y máquina
 - Reemplazó a telnet en popularidad
- Primer programa de gestión de e-mails por Larry Roberts (DARPA, 1971)
 - Mejorado por Barry Wessler añadiéndole el borrado de mensajes



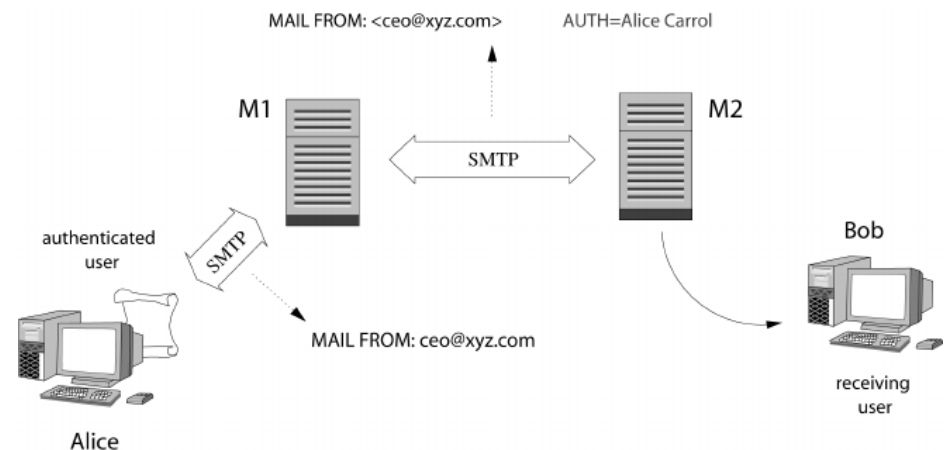
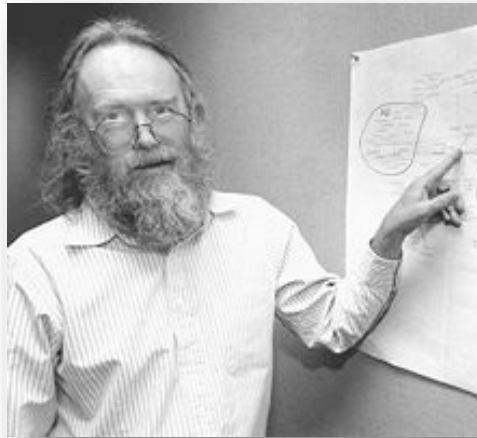
Seguridad de Servidores de E-mail



Seguridad de Servidores de E-mail

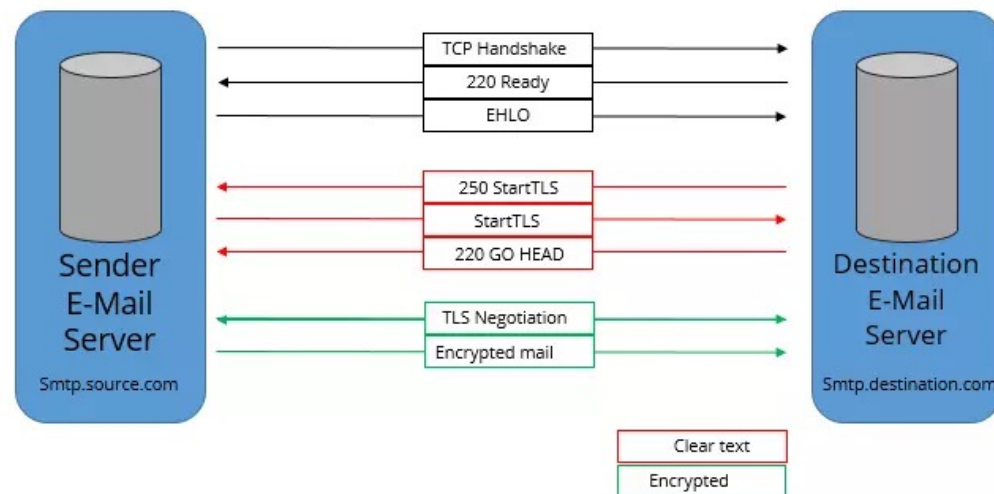
- **Servicio de correo saliente (SMTP)**

- Implementación original (John Postel, 1970) no incorporaba la autenticación de remitentes
- SMTP-AUTH (John Gardiner Myers, 1995)
 - Extensión dentro de ESMTP (Enhanced/Extended)
 - Legitima usuarios del servicio (bloquea spammers)
 - No legitima remitentes de los correos (no evita spoofing)
 - Vulnerable a la obtención de contraseñas mediante fuerza bruta



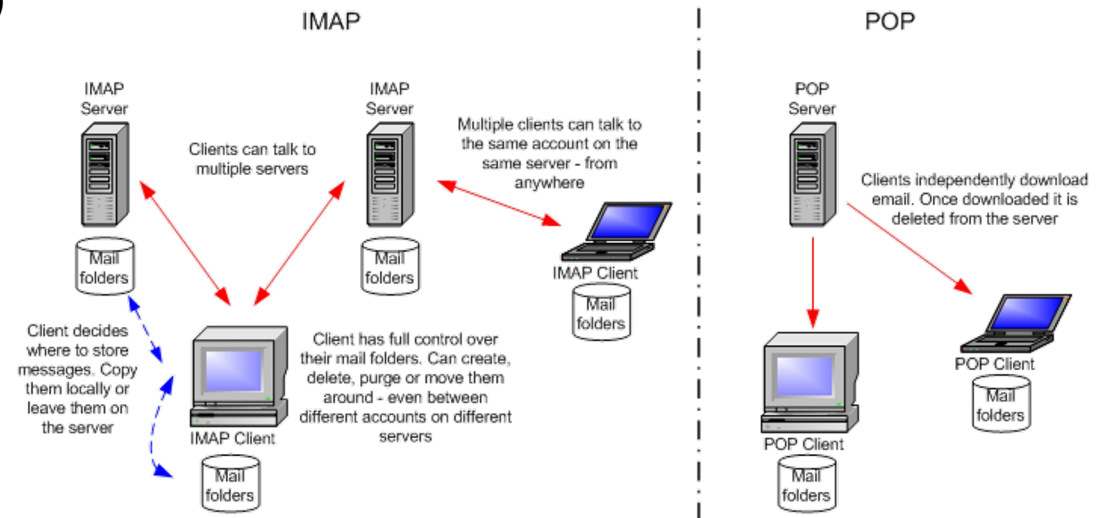
Seguridad de Servidores de E-mail

- **Servicio de correo saliente (SMTP)**
 - SMTP over TLS (SMTPS)
 - Crear un túnel TLS dentro del cual SMTP opera normalmente
 - Funcionamiento similar a HTTPS



Seguridad de Servidores de E-mail

- **Servicio de correo entrante**
 - Primeras versiones de POP en 1984 y 1985
 - IMAP diseñado en 1986
 - Primera implementación de POP3 no cifraba usuario y contraseña
 - Extensión AUTH soporta autenticación SASL (Simple Authentication and Security Layer)
 - Extensiones/mejoras:
 - APOP introduce función de hashing MD5
 - STARTTLS permite TLS (Transport Layer Security) y SSL (Secure Sockets Layer)



Seguridad de Servidores de E-mail

- **Spam**

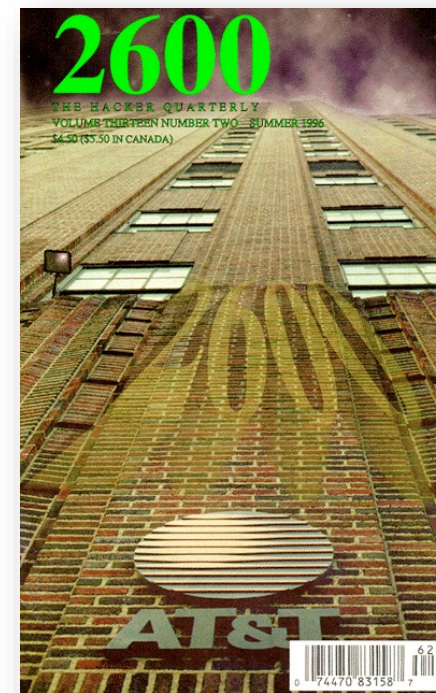
- Correo no deseado, generalmente publicitario y de remitente desconocido
- Origen en un sketch de “Monty Python” (1970)
- Historia
 - 1864: Western Union permitió mensajes masivos de una compañía
 - En Europa ya había regulación que impidió algo así
 - Década de los ‘30: cartas con ofertas de inversión a gente acomodada
 - 1978: Publicidad del nuevo modelo de Digital Equipment Corporation enviado a 393 destinatarios de ARPANET



Seguridad Usuarios E-mail y Web

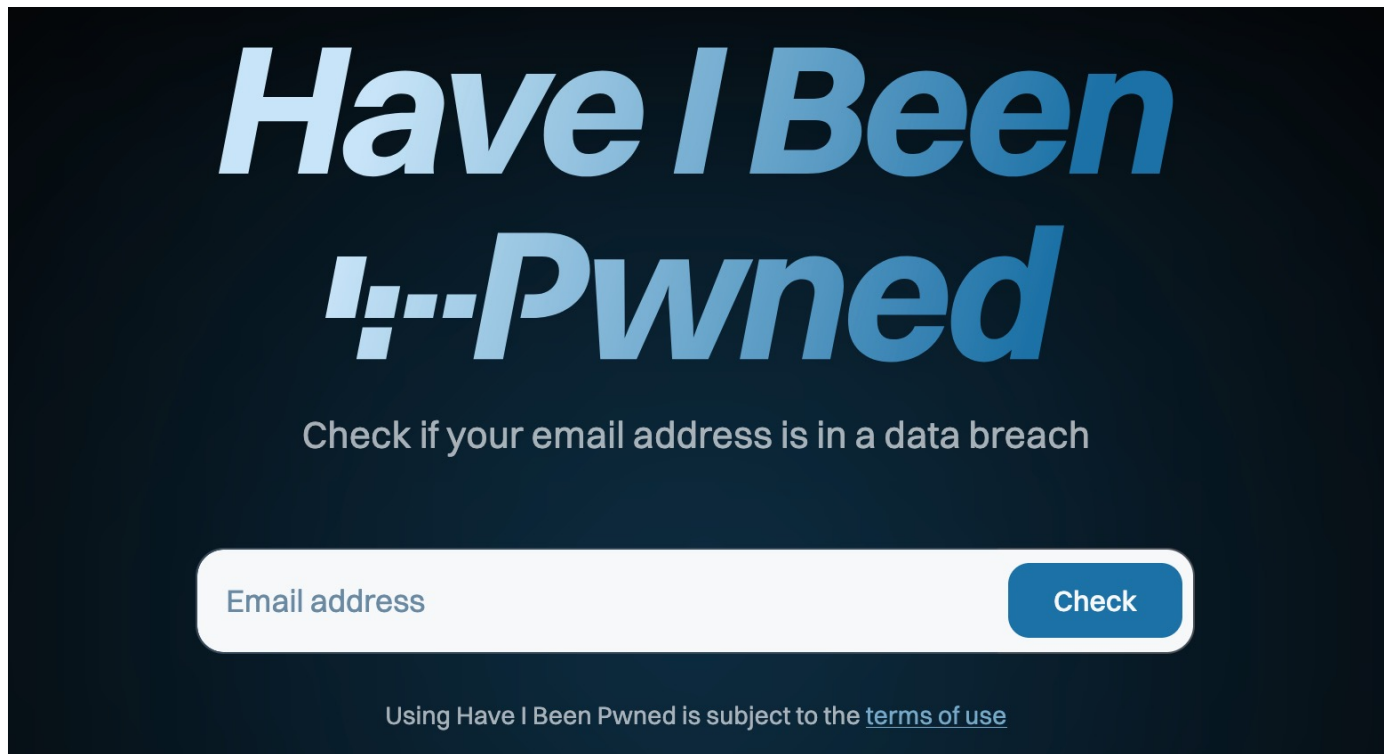
• Phishing

- Término acuñado por la revista 2600 en 1996
 - Robo de cuentas en AOL
- Aplicación de ingeniería social al entorno web
- Atacante crea un sitio con aspecto similar a uno legítimo y envía URL enmascarada en un e-mail de aspecto también legítimo
 - La URL debe parecerse lo máximo posible
- Web del atacante actúa como la legítima salvo que guarda información introducida por el usuario
 - Posteriormente redirige la conexión a la legítima
- Muchos ámbitos de aplicación: cuentas bancarias, cuentas de correo, ...





Seguridad Usuarios E-mail y Web



The image shows the 'Have I Been Pwned' website interface. It features a dark blue background with the title 'Have I Been Pwned' in large, light blue, stylized font. Below the title, the text 'Check if your email address is in a data breach' is displayed in a smaller, white font. At the bottom, there is a white input field labeled 'Email address' and a blue button labeled 'Check'. Below the input field, a small line of text states: 'Using Have I Been Pwned is subject to the [terms of use](#)'.

<https://haveibeenpwned.com/>